

ACTIVIDAD 07 DE 46 - ANALISIS ESTATICO AVANZADO CON SEMGREP Y REGLAS PROPIAS

Segunda hora de clase (50 minutos) | Trabajo practico asistido con IA

Herramienta principal: opencode (CLI). Alternativas: ChatGPT, Claude, Copilot, Gemini.

Base normativa / marco de referencia: SAST avanzado; control de calidad de codigo (dominio GA del Marco Agesic)

1. Contexto

Bandit es generico; Semgrep te permite definir tus propias reglas de seguridad. Hoy instalas Semgrep (gratis y de codigo abierto), lo ejecutas con reglas de seguridad y escribes una regla propia para el equipo, por ejemplo prohibir el uso de eval() o de datos sensibles en logs.

2. Marco teorico

¿Por que reglas propias?

Bandit trae reglas genericas. Muchos errores son especificos de tu empresa (usar una funcion prohibida, un patron inseguro propio). Semgrep permite definirlos.

¿Que es Semgrep?

Semgrep es un analizador estatico de codigo abierto que busca patrones en el codigo usando reglas definidas en texto plano.

- Reglas: describen el patron a buscar y el mensaje de alerta.
- Multi-lenguaje: funciona con varios lenguajes.
- Rapido y apto para CI.

Ejemplo de regla

Una regla puede buscar llamadas a una funcion insegura o el uso de una API desaconsejada, y marcarlas para que el equipo lo corrija.

3. Objetivos de aprendizaje

- Instalar Semgrep y ejecutar reglas de seguridad.
- Entender la sintaxis de reglas de Semgrep (pattern, message, severity).
- Escribir una regla propia adaptada a la institucion.
- Documentar el resultado y la utilidad de la regla.

4. Herramientas del día (instalacion paso a paso)

Semgrep (SAST de codigo abierto)

Analiza patrones de codigo con reglas configurables. Es rapido y se integra a Git.

1. Instala: ``pip install semgrep``.
2. Verifica: ``semgrep --version``.
3. Descarga reglas: ``semgrep --config p/security-audit`` (se descarga en la primera ejecucion).

5. Desarrollo paso a paso

Paso 1: Ejecutar Semgrep con reglas de seguridad

Ejecuta ``semgrep --config p/security-audit codigo/`` y observa los hallazgos.

Paso 2: Interpretar resultados

Pide a la IA que explique los hallazgos y los relacione con CWE.

Paso 3: Comparar con Bandit

Compara que detecta Semgrep y no Bandit (y viceversa).

Paso 4: Escribir una regla propia

Crea ``reglas/no-eval.yaml`` que prohíba ``eval()`` con severidad alta (seccion 5).

Paso 5: Ejecutar la regla

Ejecuta ``semgrep --config reglas/no-eval.yaml codigo/`` sobre un archivo de prueba.

Paso 6: Guardar la regla

Guarda la regla en la carpeta `reglas/` y haz commit.

Paso 7: Capturar evidencias

Guarda capturas de ambas ejecuciones y del archivo de la regla.

Paso 8: Documentar y reflexionar

Escribe el informe y tu reflexion.

6. Prompts sugeridos para la IA (opencode)

Copia y adapta estos mensajes en opencode (comando interactivo o ``opencode`` en terminal).

Explicame la salida de Semgrep: [pega los hallazgos]. ¿Que CWE cubren estas reglas?

Ayudame a escribir una regla de Semgrep en YAML que prohíba usar `eval()` en Python, con severidad alta, descripcion y metadata.

¿Que ventajas tiene que un equipo de seguridad defina reglas SAST propias? Da 3 ejemplos de reglas utiles para un banco.

7. Documentacion del RSI (bitacora)

Registra en `bitacora.md` de la carpeta de la actividad:

- Hallazgos de Semgrep interpretados.
- Comparacion Bandit vs Semgrep.
- Regla propia escrita y probada.
- Decision sobre integrar Semgrep al flujo de trabajo.

8. Evidencias a capturar y guardar

Guarda cada evidencia en la carpeta `evidencias/` con el nombre EVI-YYYY-MM-DD-NN-descripcion.ext y registrala en la bitacora.

- EVI-...-01-semgrep-audit.txt (ejecucion con p/security-audit).
- EVI-...-02-regla-no-eval.yaml (regla propia).
- EVI-...-03-semgrep-regla.txt (ejecucion de la regla propia).
- EVI-...-04-comparacion.png (analisis comparativo con IA).

9. Informe segun el marco de referencia

Elabora el informe de la actividad (archivo `informe.md`) que incluya:

- Metodologia (Semgrep y reglas usadas).
- Hallazgos y comparacion con Bandit.
- Regla propia: codigo, prueba y utilidad.
- Recomendacion de integracion al desarrollo.

10. Entregable de la clase

Ejecucion de Semgrep + regla propia funcionando + informe con comparacion de herramientas.

Anexo A - Informe completo para presentar al BCU

Plantilla del informe ejecutivo que el RSI entregaria al Banco Central del Uruguay (BCU) por la actividad 07 - Analisis estatico avanzado con Semgrep y reglas propias. Completa los campos [entre corchetes] con los resultados reales de la actividad y adjunta las evidencias EVI-...

Encabezado del informe

Institucion: Banco Ficticio del Uruguay

Responsable de Seguridad de la Informacion (RSI): [Nombre y cargo]

Destinatario: Banco Central del Uruguay - Superintendencia de Instituciones Financieras

Asunto: Actividad 07 - Analisis estatico avanzado con Semgrep y reglas propias

Fecha: [dd/mm/aaaa] | Version: 1.0 | Clasificacion: Confidencial

1. Resumen ejecutivo

[2 a 5 parrafos breves: que se realizo, en que marco normativo, que se encontro, que se corrigio y el estado actual. Debe poder leerse en 1 minuto por un directivo.]

2. Marco normativo y regulatorio aplicable

- Norma de Seguridad de la Informacion y Ciberseguridad del BCU (SF.SEG.08).
- Recopilacion de Normas de Regulacion y Control del Sistema Financiero (RNRCSF).
- Circular sobre gestion de incidentes y notificacion de eventos de ciberseguridad.
- Normativa interna del Banco Ficticio del Uruguay: [politica de seguridad, plan de trabajo RSI].

3. Alcance y metodologia

- Alcance: [activos, procesos, sistemas o areas cubiertos por la actividad].
- Metodo: [pruebas tecnicas, revision documental, simulacion, escaneo, etc.].
- Herramientas utilizadas: Semgrep (SAST de codigo abierto).
- Periodo de ejecucion: [fecha de inicio] a [fecha de fin].

4. Descripcion de la actividad

Bandit es generico; Semgrep te permite definir tus propias reglas de seguridad. Hoy instalas Semgrep (gratis y de codigo abierto), lo ejecutas con reglas de seguridad y escribes una regla propia para el equipo, por ejemplo prohibir el uso de eval() o de datos sensibles en logs.

5. Resultados obtenidos

- Objetivo: Instalar Semgrep y ejecutar reglas de seguridad. -> [Logrado / Parcial / No logrado]
- Objetivo: Entender la sintaxis de reglas de Semgrep (pattern, message, severity). -> [Logrado / Parcial / No logrado]
- Objetivo: Escribir una regla propia adaptada a la institucion. -> [Logrado / Parcial / No logrado]
- Objetivo: Documentar el resultado y la utilidad de la regla. -> [Logrado / Parcial / No logrado]

6. Riesgos identificados y evaluacion

Tabla de riesgos detectados con impacto en la institucion financiera:

ID Riesgo	Descripcion	Probabilidad	Impacto	Nivel	Tratamiento
R-01	[riesgo]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado /

	encontrado]				Aceptado / En plan]
R-02	[riesgo encontrado]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado / Aceptado / En plan]

7. Controles implementados

Descripcion de los controles aplicados y su estado:

- Control: Instala y ejecuta Semgrep -> [Implementado / Parcial / Pendiente]
- Control: Interpreta los hallazgos de seguridad -> [Implementado / Parcial / Pendiente]
- Control: Compara Semgrep con Bandit -> [Implementado / Parcial / Pendiente]
- Control: Escribe y prueba una regla propia -> [Implementado / Parcial / Pendiente]
- Control: Documenta y guarda evidencias -> [Implementado / Parcial / Pendiente]

8. Incidentes de seguridad relacionados

[Ninguno en esta actividad. O bien: fecha, tipo, clasificacion, datos afectados, impacto y medidas adoptadas. Si corresponde, nota que ya se notifico al BCU en los plazos reglamentarios.]

9. Indicadores y metricas de la actividad

- Tiempo de ejecucion: [X] horas.
- Hallazgos: [X] altos, [X] medios, [X] bajos.
- Hallazgos corregidos: [X] / [X].
- Cobertura: [X]% de los activos del alcance.

10. Plan de accion y proximos pasos

Accion	Responsable	Plazo	Estado
[accion pendiente]	[cargo]	[dd/mm/aaaa]	Pendiente

11. Conclusion

[Conclusion ejecutiva: postura de seguridad de la institucion tras la actividad y compromiso de seguimiento.]

12. Firma y aprobacion

Firma del RSI: _____ Fecha: [dd/mm/aaaa]

Visto bueno del area de negocio / Direccion: _____

Anexos: evidencias EVI-... registradas en la bitacora.

Anexo B - Como presentar la actividad a AGESIC

Guia de estructura y contenido para comunicar la actividad 07 - Analisis estatico avanzado con Semgrep y reglas propias a la Agencia para el Desarrollo del Gobierno de Gestion Electronica y la

Sociedad de la Informacion (AGESIC), alineada al marco de ciberseguridad de referencia para Uruguay.

Encuadre institucional

- Organismo: Banco Ficticio del Uruguay, dependencia publica.
- RSI: [Nombre y cargo] | Correo: [correo institucional].
- Fecha de presentacion: [dd/mm/aaaa] | Periodo cubierto: [periodo].

1. Presentacion del responsable

Quien es el RSI, su rol, a que direccion reporta y como se vincula con la gestion de la seguridad de la informacion en el Banco Ficticio del Uruguay.

2. Objetivo de la actividad

Bandit es generico; Semgrep te permite definir tus propias reglas de seguridad. Hoy instalas Semgrep (gratis y de codigo abierto), lo ejecutas con reglas de seguridad y escribes una regla propia para el equipo, por ejemplo prohibir el uso de eval() o de datos sensibles en logs.

- Objetivo: Instalar Semgrep y ejecutar reglas de seguridad.
- Objetivo: Entender la sintaxis de reglas de Semgrep (pattern, message, severity).
- Objetivo: Escribir una regla propia adaptada a la institucion.
- Objetivo: Documentar el resultado y la utilidad de la regla.

3. Marco de referencia utilizado

- Marco normativo de ciberseguridad aplicable (AGESIC / normativa nacional).
- Ley 18.331 de Proteccion de Datos Personales y su Decreto Reglamentario.
- Guia o documento de base: SAST avanzado; control de calidad de codigo (dominio GA del Marco Agesic)
- Estandares de buenas practicas: [ISO/IEC 27001, NIST CSF, OWASP, etc.].

4. Metodologia y herramientas

Como se desarrollo la actividad y con que herramientas (Semgrep (SAST de codigo abierto)).

5. Resultados y evidencias

Descripcion de lo obtenido, con referencia a las evidencias guardadas:

- Evidencia: EVI-...-01-semgrep-audit.txt (ejecucion con p/security-audit).
- Evidencia: EVI-...-02-regla-no-eval.yaml (regla propia).
- Evidencia: EVI-...-03-semgrep-regla.txt (ejecucion de la regla propia).
- Evidencia: EVI-...-04-comparacion.png (analisis comparativo con IA).

6. Hallazgos, riesgos y recomendaciones

Presentacion de hallazgos ordenados por criticidad y las recomendaciones asociadas:

ID	Hallazgo	Criticidad	Recomendacion	Estado
H-01	[hallazgo]	[C/A/M/B]	[recomendacion]	[Abierto / Cerrado]

7. Gestion de incidentes (si aplica)

- Tipificacion del evento y datos involucrados.
- Notificacion a la Unidad Reguladora y de Control de Datos Personales si se vieron afectados datos personales.
- Lecciones aprendidas y mejoras al plan de respuesta.

8. Plan de mejora y continuidad

Mejora planificada	Responsable	Plazo	Prioridad
[mejora]	[cargo]	[dd/mm/aaaa]	[A/M/B]

9. Compromisos y firmas

El Banco Ficticio del Uruguay se compromete a [seguimiento, capacitacion, revision periodica] y presenta este informe para conocimiento de AGESIC.

Firma del RSI: _____ Sello del organismo: _____

11. Rubrica de evaluacion

Criterio	Logrado (3)	En desarrollo (2)	No logrado (1)
Instala y ejecuta Semgrep			
Interpreta los hallazgos de seguridad			
Compara Semgrep con Bandit			
Escribe y prueba una regla propia			
Documenta y guarda evidencias			

12. Checklist de cierre

- ☐ Ejecuté Semgrep con p/security-audit.
- ☐ Escribí una regla propia y la probé.
- ☐ Guardé las evidencias y el informe.

13. Reflexion sobre el uso de IA

¿Por que un RSI deberia poder escribir reglas de analisis para el equipo? ¿Que reglas prohibirias en tu organizacion?